PART 11 — COMPLIANCE, HMRC & PRIVACY CHECKLIST

Target Jurisdiction: United Kingdom

Statutory Authorities: HMRC, UK Companies House, Information Commissioner's Office (ICO)

Governing Legislation: Companies Act 2006, UK GDPR / Data Protection Act 2018, Value Added Tax Act 1994

1. Statutory Background & Legal Mandates (Non-Technical Explanation)

In the United Kingdom, accounting is not just a business practice—it is a matter of statutory law:

1. **The 6-Year Rule (Companies Act 2006, Section 388):** A limited company must preserve its accounting records for at least **6 years** from the end of the financial year to which they relate. If a company deletes its ledgers prematurely or fails to produce them during an HMRC tax inspection, company directors can face personal criminal fines and disqualification.
2. **Making Tax Digital (MTD) for VAT:** Under UK tax regulations, businesses cannot copy-paste numbers from spreadsheets into web forms. The accounting software must maintain an unbroken "digital link" from the initial sales invoice straight into the general ledger and the 9-box VAT return.
3. **UK GDPR vs. Accounting Law:** Under GDPR, individuals have the "Right to be Forgotten" (requesting their data be deleted). However, under GDPR Article 17(3)(b), the Right to Erasure does **NOT** apply when data retention is required by statutory law (e.g., maintaining financial transaction history for HMRC). blynt handles this by anonymizing personal user profiles while preserving immutable financial audit ledgers.

2. Statutory Compliance Audit Matrix

Statutory Mandate	Legal Requirement	blynt Technical Implementation	Verification Method	Status
Companies Act 2006 Section 386	Keep records showing accurate financial position at all times.	Fixed-point `NUMERIC(19,4)` math; dual debit/credit validation engine.	Automated unit tests verifying Fundamental Accounting Equation.	**COMPLIANT**
Companies Act 2006 Section 388	Retain records for a minimum of 6 years from year-end.	Append-only database storage; `HARD_LOCKED` periods block deletion.	PostgreSQL trigger blocks `DELETE` on validated journals and periods.	**COMPLIANT**
VAT Act 1994 & MTD Regulations	Digital records and automated links between invoices and VAT accounts.	Sales invoice approval automatically posts to Account `2100 - VAT Output Tax`.	Automated integration test verifying subledger-to-GL posting.	**COMPLIANT**
Data Protection Act 2018 (UK GDPR)	Subject Access Request (SAR) capability for personal data.	Export endpoints for user session history, profile metadata, and	JSON / CSV data export pipeline.	**COMPLIANT**

		activity logs.		
UK Data Sovereignty	Accounting records stored within UK / approved jurisdiction.	Cloud production database deployed in AWS London (`eu-west-2`).	AWS Infrastructure-as-Code Terraform configuration verification.	**COMPLIANT**

3. HMRC Making Tax Digital (MTD) 9-Box VAT Derivation

blynt's general ledger maps directly to the UK standard 9-box VAT return format:

- **Box 1 (VAT due on sales):** Total credit balance of Account `2100 (VAT Output Tax)` for the return period.
- **Box 2 (VAT due on acquisitions from EU):** Reconciled via EU reverse-charge nominal accounts.
- **Box 3 (Total VAT due):** Calculated as `Box 1 + Box 2`.
- **Box 4 (VAT reclaimed on purchases):** Total debit balance of Account `2110 (VAT Input Tax)` for allowable business expenses.
- **Box 5 (Net VAT payable or repayable):** Calculated as `|Box 3 - Box 4|`.
- **Box 6 (Total value of sales excluding VAT):** Sum of all credit entries in Nominal Class 4000 (Sales Revenue).
- **Box 7 (Total value of purchases excluding VAT):** Sum of all debit entries in Nominal Class 5000 (Cost of Sales & Expenses).
- **Box 8 & 9 (Total value of goods supplied to / acquired from EU Member States):** Export/import subledger tags.

4. Privacy & Data Handling Policy (UK GDPR)

4. **Lawful Basis for Processing:** Processing of financial transaction data is conducted under **Legal Obligation** (GDPR Article 6(1)(c)) and **Contractual Performance** (GDPR Article 6(1)(b)).
5. **PII Anonymization on Account Closure:**

- When a user deletes their profile, their email, display name, and password hash in `users` are scrubbed and replaced with cryptographic pseudonyms (`deleted_user_xyz`).
- Financial transactions posted by that user remain preserved in `journal_entries` and `audit_logs` referencing the pseudonym, maintaining ledger integrity while respecting privacy rights.